Seguridad en la nube

Conceptos, controles y gestión de riesgos

Asignatura: Seguridad de los Sistemas de Información · 5.º año de ISI UTN FRRO

1. ¿Qué significa proteger la nube?

La seguridad en la nube es el conjunto de políticas, procesos, tecnologías y prácticas destinados a proteger los datos, las identidades, las aplicaciones y la infraestructura que se ejecutan en servicios cloud. No consiste simplemente en trasladar a Internet los controles del centro de datos tradicional. El entorno es dinámico: los recursos se crean y eliminan mediante consolas, API, plantillas de infraestructura como código y procesos automatizados.

Por ello, una configuración incorrecta puede exponer información en minutos; una credencial filtrada puede permitir operar recursos desde cualquier ubicación; y un registro insuficiente puede dificultar reconstruir lo ocurrido. La seguridad debe diseñarse desde la arquitectura y verificarse continuamente, no agregarse al final.

Principios rectores

- Confidencialidad: solo las personas y servicios autorizados acceden a la información.
- Integridad: los datos y configuraciones no se modifican de forma no autorizada.
- Disponibilidad: los servicios siguen funcionando o se recuperan dentro de objetivos definidos.
- Trazabilidad: las acciones relevantes quedan registradas y pueden investigarse.
- Responsabilidad: cada control tiene un propietario, una evidencia y un mecanismo de revisión.



Modelos de nube y responsabilidad compartida

2. Modelos de servicio

La ubicación de los controles depende de cuánto administra el proveedor y cuánto conserva el cliente. Los nombres comerciales pueden variar, pero la distinción conceptual es útil para asignar responsabilidades.

Infraestructura como servicio (IaaS)

El proveedor opera los centros de datos, el hardware y buena parte de la capa de virtualización. El cliente suele administrar sistemas operativos, parches del sistema invitado, identidades, aplicaciones, reglas de red y datos. Una máquina virtual expuesta con puertos innecesarios o con una contraseña débil sigue siendo responsabilidad del cliente.

Plataforma como servicio (PaaS)

El proveedor administra el sistema operativo y el entorno de ejecución de la plataforma. El cliente se concentra en el código, los permisos de la aplicación, las dependencias, los secretos, los datos y las configuraciones del servicio. PaaS reduce tareas operativas, pero no elimina los errores de diseño ni los permisos excesivos.

Software como servicio (SaaS)

La aplicación completa se consume como servicio. El proveedor mantiene la plataforma, pero el cliente suele configurar usuarios, autenticación, permisos, compartición de archivos, retención y clasificación de información. Una carpeta compartida públicamente en una suite colaborativa puede provocar una fuga sin que exista una vulnerabilidad en el software.

3. Responsabilidad compartida

El modelo de responsabilidad compartida establece que el proveedor protege la infraestructura que opera, mientras que el cliente protege lo que despliega y configura dentro de los límites del servicio. La frontera exacta cambia según el servicio, el contrato y las opciones habilitadas. Nunca debe suponerse que “estar en la nube” significa que el proveedor se ocupa de todo.

Área	Proveedor (habitual)	Cliente (habitual)
Centro de datos	Edificio, energía, acceso físico	Verificar garantías y reportes
Sistema operativo IaaS	Infraestructura subyacente	Parches, hardening y configuración
Identidades	Herramientas de identidad disponibles	Usuarios, MFA, roles y revisiones
Datos	Durabilidad del servicio contratado	Clasificación, acceso, cifrado y retención
Aplicaciones	Plataforma administrada según servicio	Código, dependencias y lógica de negocio

Actividad breve: para una aplicación web alojada en una máquina virtual y para una aplicación SaaS de correo, enumerar tres controles que administra el cliente en cada caso. Explicar qué evidencia permitiría comprobar que funcionan.

Identidades, accesos y secretos

4. Gestión de identidades y accesos (IAM)

La identidad es uno de los perímetros principales de la nube. Los recursos pueden estar distribuidos entre regiones y redes, por lo que la autorización debe acompañar a cada usuario, aplicación y proceso automatizado. El objetivo es permitir únicamente las acciones necesarias, durante el tiempo necesario y sobre los recursos correspondientes.

Controles fundamentales

- Autenticación multifactor (MFA): exigir un segundo factor, priorizando métodos resistentes al phishing cuando estén disponibles.
- Mínimo privilegio: asignar permisos específicos y evitar roles administrativos permanentes para tareas cotidianas.
- Separación de funciones: evitar que una misma identidad pueda, sin control, solicitar, aprobar y ejecutar operaciones críticas.
- Identidades de carga de trabajo: usar roles o identidades administradas para aplicaciones en lugar de claves estáticas embebidas en el código.
- Revisión periódica: retirar accesos de personas que cambian de función o dejan la organización y detectar cuentas inactivas.
- Acceso privilegiado temporal: elevar privilegios con aprobación, duración limitada y registro de actividad.

5. Credenciales y claves

Las claves de API, contraseñas de bases de datos, certificados privados y tokens de acceso son secretos. Guardarlos en repositorios de código, imágenes de contenedores, scripts o archivos compartidos crea un riesgo importante: quien obtenga el secreto podría acceder al servicio sin explotar una vulnerabilidad técnica.

Se recomienda utilizar un gestor de contraseñas, limitar qué identidades pueden leer cada secret, registrar su uso y rotarlos ante una sospecha de exposición. Las credenciales no deben incluirse en repositorios, ni siquiera privados, porque el historial puede conservarlas después de borrar el archivo.

Ejemplo de configuración

Una aplicación necesita leer objetos de un único contenedor de almacenamiento. Una política excesiva le concede administración total de la cuenta. Una política de mínimo privilegio le permite listar y leer únicamente los objetos necesarios. Si la aplicación también debe cargar informes, se agrega la operación de escritura solo sobre la ruta correspondiente.

Señales de alerta

- Inicios de sesión desde ubicaciones o dispositivos inusuales.
- Creación inesperada de usuarios, claves o roles privilegiados.
- Desactivación de MFA o modificación de políticas de acceso.
- Uso de credenciales fuera del horario o patrón operativo esperado.

La detección debe correlacionar eventos de identidad con cambios de configuración y actividad de recursos. Una alerta aislada puede ser legítima; una secuencia de autenticación anómala, creación de privilegios y descarga masiva exige investigación prioritaria.

Protección de datos y criptografía

6. Clasificación y ciclo de vida de los datos

Antes de seleccionar controles, la organización debe identificar qué información almacena, dónde reside, quién la utiliza y cuánto tiempo necesita conservarla. No todos los datos tienen el mismo impacto: datos públicos, internos, confidenciales y regulados requieren tratamientos diferentes. La clasificación orienta permisos, cifrado, retención, monitoreo y respuesta ante incidentes.

El ciclo de vida incluye creación o captura, almacenamiento, procesamiento, transferencia, archivo y eliminación. La seguridad debe cubrir todas las etapas. Borrar un archivo de una carpeta no garantiza que desaparezca de copias, versiones, instantáneas o respaldos sujetos a políticas de retención.

7. Cifrado en tránsito y en reposo

El cifrado en tránsito protege la comunicación entre clientes, aplicaciones y servicios; normalmente se implementa con TLS correctamente configurado. El cifrado en reposo protege datos almacenados en discos, bases de datos, objetos y respaldos. En ambos casos, el cifrado debe acompañarse de una gestión adecuada de claves.

Las claves pueden ser administradas por el proveedor o por el cliente, según las capacidades del servicio y los requisitos de control. La organización debe definir quién puede crear, usar, rotar, deshabilitar y recuperar claves. Una política de cifrado no sirve si una identidad comprometida puede acceder libremente tanto a los datos como a las claves.

8. Copias de seguridad y recuperación

La replicación mejora disponibilidad, pero no reemplaza un backup: una eliminación accidental, un error lógico o el cifrado malicioso de archivos puede replicarse. Una estrategia robusta mantiene copias separadas, limita quién puede borrarlas y prueba regularmente la restauración.

- Definir RPO (Recovery Point Objective): cantidad máxima de pérdida de datos aceptable, expresada como tiempo.
- Definir RTO (Recovery Time Objective): tiempo objetivo para recuperar el servicio.
- Proteger respaldos con cifrado, control de acceso, retención y, cuando sea viable, inmutabilidad.
- Ejecutar pruebas de restauración documentadas; comprobar consistencia de datos y funcionamiento de la aplicación.

9. Privacidad y ubicación

La región donde se almacenan o procesan datos puede tener implicancias contractuales, regulatorias y operativas. Antes de elegir un servicio se deben analizar la jurisdicción aplicable, las transferencias internacionales, los subencargados, la eliminación y la notificación de incidentes. En Argentina, el tratamiento de datos personales debe evaluarse considerando la Ley 25.326 y las obligaciones aplicables al caso concreto. Esta referencia no reemplaza el asesoramiento jurídico.

Una buena práctica es mantener un inventario de datos y servicios, registrar su clasificación y vincular cada conjunto de datos con un responsable de negocio.

Redes, aplicaciones y cargas de trabajo

10. Seguridad de red en la nube

Las redes virtuales, subredes, tablas de rutas, firewalls y grupos de seguridad permiten definir qué recursos pueden comunicarse. La regla general es denegar por defecto y habilitar únicamente los flujos requeridos. No se deben publicar servicios de administración —por ejemplo, SSH o RDP— a Internet sin una necesidad justificada y controles reforzados.

- Separar capas web, aplicación, datos y administración mediante subredes y reglas explícitas.
- Restringir los orígenes, destinos, protocolos y puertos a lo indispensable.
- Usar VPN o mecanismos de acceso privado para administración cuando corresponda.
- Registrar flujos de red y revisar reglas amplias, obsoletas o sin propietario.
- Proteger DNS, balanceadores, APIs y puntos de entrada públicos.

11. Endurecimiento de sistemas y contenedores

Las máquinas virtuales deben partir de imágenes confiables y mantenidas. Se deben deshabilitar servicios innecesarios, aplicar parches, configurar registros, proteger el acceso administrativo y verificar la postura de seguridad de forma continua. Las imágenes base deben actualizarse para evitar que nuevas instancias nazcan con vulnerabilidades conocidas.

En contenedores, la imagen no debe incluir secretos ni herramientas innecesarias. Conviene ejecutar procesos sin privilegios, limitar capacidades, fijar versiones de imágenes, escanear dependencias y evitar el uso de contenedores privilegiados salvo justificación. Un contenedor no constituye por sí solo una frontera de seguridad completa.

12. Desarrollo seguro y automatización

La infraestructura como código permite revisar y versionar redes, permisos y recursos. También puede propagar errores a gran escala: una plantilla que crea almacenamiento público podría replicarse en múltiples entornos. Por eso, los cambios deben someterse a revisión, pruebas automáticas y aprobación proporcional al riesgo.

- Analizar código, dependencias, imágenes y plantillas antes del despliegue.
- Separar entornos de desarrollo, prueba y producción.
- Proteger los pipelines de CI/CD y limitar sus permisos.
- Usar secretos administrados y evitar credenciales de larga duración.
- Detectar desviaciones entre la configuración aprobada y el estado real.

13. Amenazas frecuentes

Entre los incidentes comunes se encuentran los permisos excesivos, almacenamiento expuesto, credenciales robadas, APIs mal protegidas, software sin parches, abuso de recursos para minería no autorizada, ataques de denegación de servicio y fallas de disponibilidad del proveedor. También existen riesgos de dependencia: una interrupción regional o un cambio contractual puede afectar la continuidad.

La defensa en profundidad combina identidad, segmentación, hardening, protección de datos, monitoreo y recuperación. Ningún control aislado elimina el riesgo; la arquitectura debe asumir que algunas barreras pueden fallar.

Monitoreo, auditoría y respuesta a incidentes

14. Registro y monitoreo

Los registros permiten detectar comportamientos anómalos y reconstruir acciones. Deben capturarse eventos de autenticación, cambios de políticas, creación o eliminación de recursos, actividad administrativa, accesos a datos sensibles y eventos de red relevantes. La cobertura debe incluir cuentas, regiones y servicios utilizados por la organización.

Los logs deben centralizarse en un repositorio protegido frente a modificación o borrado por los mismos administradores que se investigan. Se deben definir retención, control de acceso, sincronización horaria y procedimientos de consulta. Registrar todo sin capacidad de analizarlo produce costos y ruido, no necesariamente seguridad.

15. Detección y métricas

Las alertas deben basarse en riesgo y contexto. Algunos ejemplos son la creación de una clave privilegiada, cambios en reglas de firewall, desactivación del registro, exportaciones masivas de datos o gasto inusual de recursos. La correlación entre señales mejora la precisión y permite priorizar incidentes.

Indicadores útiles incluyen tiempo medio de detección, tiempo medio de contención, porcentaje de recursos con registros habilitados, cumplimiento de parches, cuentas privilegiadas con MFA, vulnerabilidades críticas pendientes y porcentaje de restauraciones probadas con éxito.

16. Respuesta ante incidentes cloud

Un procedimiento de respuesta debe definir roles, contactos, criterios de severidad, facultades de contención y mecanismos de preservación de evidencia. En la nube, algunas acciones son rápidas —revocar una clave, aislar una instancia o bloquear un flujo—, pero pueden afectar servicios legítimos. Las decisiones deben considerar impacto, urgencia y continuidad.

Secuencia inicial sugerida

- Preparación: inventario de activos, registros habilitados, responsables, playbooks y ejercicios.
- Identificación: validar alertas, determinar alcance, recursos afectados, identidad involucrada y ventana temporal.
- Contención: revocar credenciales, restringir accesos o aislar recursos comprometidos sin destruir evidencia.
- Erradicación y recuperación: corregir la causa, reconstruir desde imágenes confiables, rotar secretos y restaurar datos verificados.
- Lecciones aprendidas: documentar cronología, impacto, decisiones, brechas de control y acciones con responsables y fechas.

17. Caso breve: almacenamiento expuesto

Una organización detecta que un repositorio de archivos con informes internos permite lectura pública. La respuesta debe comenzar por confirmar la exposición y su alcance, restringir el acceso, preservar registros y determinar qué objetos pudieron consultarse. Luego se revisan permisos heredados, plantillas y procesos que generaron la configuración.

No alcanza con cerrar el acceso: es necesario investigar si hubo descargas, corregir el origen de la configuración, revisar otros repositorios y evaluar obligaciones de notificación. La comunicación debe basarse en hechos confirmados y coordinarse con las áreas técnicas, legales y de negocio.

Gobierno, cumplimiento y gestión del riesgo

18. Gobierno de seguridad cloud

El gobierno establece quién puede contratar servicios, aprobar arquitecturas, clasificar datos, aceptar riesgos y verificar controles. Sin reglas claras, distintas áreas pueden crear cuentas y servicios sin inventario, presupuesto ni supervisión. Una política cloud debe definir servicios autorizados, requisitos mínimos, responsables, excepciones y criterios de salida.

- Inventario centralizado de cuentas, suscripciones, proyectos, regiones, servicios y propietarios.
- Proceso de evaluación de riesgo antes de incorporar un proveedor o servicio crítico.
- Estándares para identidades, redes, cifrado, logs, backups y gestión de vulnerabilidades.
- Revisión periódica de permisos, costos, configuración y cumplimiento de políticas.
- Plan de salida: exportación de datos, portabilidad, eliminación verificada y continuidad.

19. Riesgo de terceros y contratos

La evaluación de proveedores debe considerar disponibilidad, historial de incidentes, controles de acceso, cifrado, ubicación de datos, subcontratistas, soporte, auditorías y tiempos de notificación. Los acuerdos de nivel de servicio (SLA) describen compromisos, pero no sustituyen una evaluación de riesgo ni garantizan que el negocio pueda recuperarse.

Es importante identificar dependencias críticas, límites de responsabilidad, mecanismos de exportación y costos de egreso. La estrategia multicloud no es automáticamente más segura: puede aumentar complejidad, duplicar errores y requerir capacidades adicionales.

20. Marcos y referencias

Los marcos de buenas prácticas ayudan a organizar controles y evidencias. No son una receta universal; deben adaptarse al tamaño de la organización, criticidad de los datos y obligaciones aplicables.

- NIST Cybersecurity Framework 2.0: organiza la gestión del riesgo en funciones de gobierno, identificación, protección, detección, respuesta y recuperación.
- NIST SP 800-53: catálogo amplio de controles de seguridad y privacidad.
- ISO/IEC 27001: sistema de gestión de seguridad de la información; ISO/IEC 27017 aporta orientación para controles de seguridad en servicios cloud.
- CIS Benchmarks: recomendaciones técnicas de configuración segura para plataformas específicas.
- Documentación oficial del proveedor: modelo de responsabilidad compartida, guías de arquitectura y servicios de seguridad.

21. Evaluación de riesgo

Una evaluación puede estimar probabilidad e impacto, identificar controles existentes y definir tratamiento: mitigar, transferir, evitar o aceptar formalmente. Por ejemplo, una base de datos expuesta públicamente con datos personales combina una alta superficie de ataque con consecuencias potencialmente graves. La prioridad debe reflejar el riesgo real y no solo la cantidad de alertas.

Cada riesgo debería tener un propietario, una fecha objetivo, una decisión documentada y evidencia de cierre. Las excepciones deben ser temporales, justificadas y revisadas.

Lista de verificación inicial

- ¿Hay MFA para accesos administrativos y revisión de cuentas privilegiadas?
- ¿Los servicios públicos tienen una justificación y exposición mínima?
- ¿Los datos sensibles están clasificados, cifrados y respaldados?
- ¿Se centralizan logs y se prueban alertas e incidentes?
- ¿Se prueban restauraciones y existe un plan de salida del proveedor?

Actividad de cierre

Preguntas de repaso

1. ¿Por qué el proveedor cloud no es responsable de toda la seguridad?
2. ¿Qué diferencias de responsabilidad existen entre IaaS, PaaS y SaaS?
3. ¿Cómo se aplica el mínimo privilegio a una aplicación que accede a una base de datos?
5. ¿Por qué centralizar logs no garantiza por sí solo una detección efectiva?
6. ¿Qué pasos tomaría ante la filtración de una clave de API?
7. ¿Qué riesgos debe contemplar una organización al elegir la región y el proveedor?

Conclusión

La seguridad en la nube es una responsabilidad continua que combina arquitectura, configuración, identidad, protección de datos, monitoreo y gobierno. La automatización permite aplicar controles a escala, pero también puede multiplicar errores. La organización debe conocer sus activos, definir responsabilidades, reducir privilegios, observar los cambios y comprobar que puede recuperarse.

La pregunta central no es si la nube es segura en términos absolutos, sino si los riesgos del servicio elegido son conocidos, aceptables y tratados con controles verificables.

Bibliografía y recursos para ampliar

NIST, Cybersecurity Framework 2.0: https://www.nist.gov/cyberframework

NIST SP 800-53, Security and Privacy Controls: https://csrc.nist.gov/publications/detail/sp/800-53/rev-5/final

ISO/IEC 27001 e ISO/IEC 27017: consultar el catálogo oficial de ISO: https://www.iso.org/

Cloud Security Alliance, Cloud Controls Matrix y guías de seguridad cloud: https://cloudsecurityalliance.org/

Documentación oficial de seguridad del proveedor cloud elegido (por ejemplo, AWS, Microsoft Azure o Google Cloud).